

Por uma Doutrina Proativa 360° de Ciber Segurança e Resiliência

José A. S. Alegria



Redshift Board Advisor

CIWA Ambassador and Strategy Advisor

Former Chief Security Officer & CISO, Altice Portugal

Former Worldwide Coordinator for the CyberWatch Program, Altice Group

Membro fundador do Colégio de Eng^a Informática da Ordem dos Engenheiros

Former Advisor, European Cybercrime Center



Cyber**security**.

25 de março de 2026

redShift

**O *Ransomware* continua a ser o
instrumento mais usado pelo
Cibercrime Organizado e o que deve
mais preocupar qualquer *CISO*!**

Um ataque de *Ransomware* bem sucedido poderá ter consequências catastróficas nas operações do seu alvo, para além da mais do que provável exfiltração de informação crítica → *Ataques 2 em 1!*

**E é importante notar que os seus
vetores iniciais de entrada
continuam a ser praticamente os
mesmos!**

1. Aproveitamento de **contas comprometidas** sem 2FA/MFA.
 - **Initial Access Brokers (IAB)** -- Grupos criminosos especializados no roubo de credenciais!
2. Aproveitamento de **portas RDP** expostas à Internet.
 - Idem para o **ICA** (mas em menor grau).
3. Aproveitamento de **vulnerabilidades** conhecidas, mas sem **"patch"** ainda aplicado.
4. Recurso a **"SEO Poisoning"**.
5. Recurso a processos de **"Força Bruta"** não mitigados.
6. Recurso a **Engenharia Social** (agora também via MS Teams).
7. ...

E depois movimento lateral, com aquisição de novas credenciais (*via mimikatz*) e escalada de privilégios, ... sem detecção em tempo útil pelo SOC!

***“Modus Operandi”* de ataques de alto impacto em Portugal**

Ataques de Elevado impacto em Portugal: Nos últimos 4 a 5 anos



Ataques de Elevado impacto em Portugal: Nos últimos 4 a 5 anos



Contra-Medidas em Falta!

1. Uso de credenciais roubadas!
2. 2FA/MFA, se existente, foi inefetivo!
3. Os ataques foram detetados “**POST FACTUM**”!
 - Ausência de alarmes? [**FALSE NEGATIVES?**]
 - Demasiados alarmes? Alarm Fatigue? [**TOO MANY FALSE POSITIVES?**]
4. Em qualquer dos casos... demoraram demasiado tempo a recuperar as operações!

24 abril 2022  **Garcia de Orta** E.P.E.

...

redShift

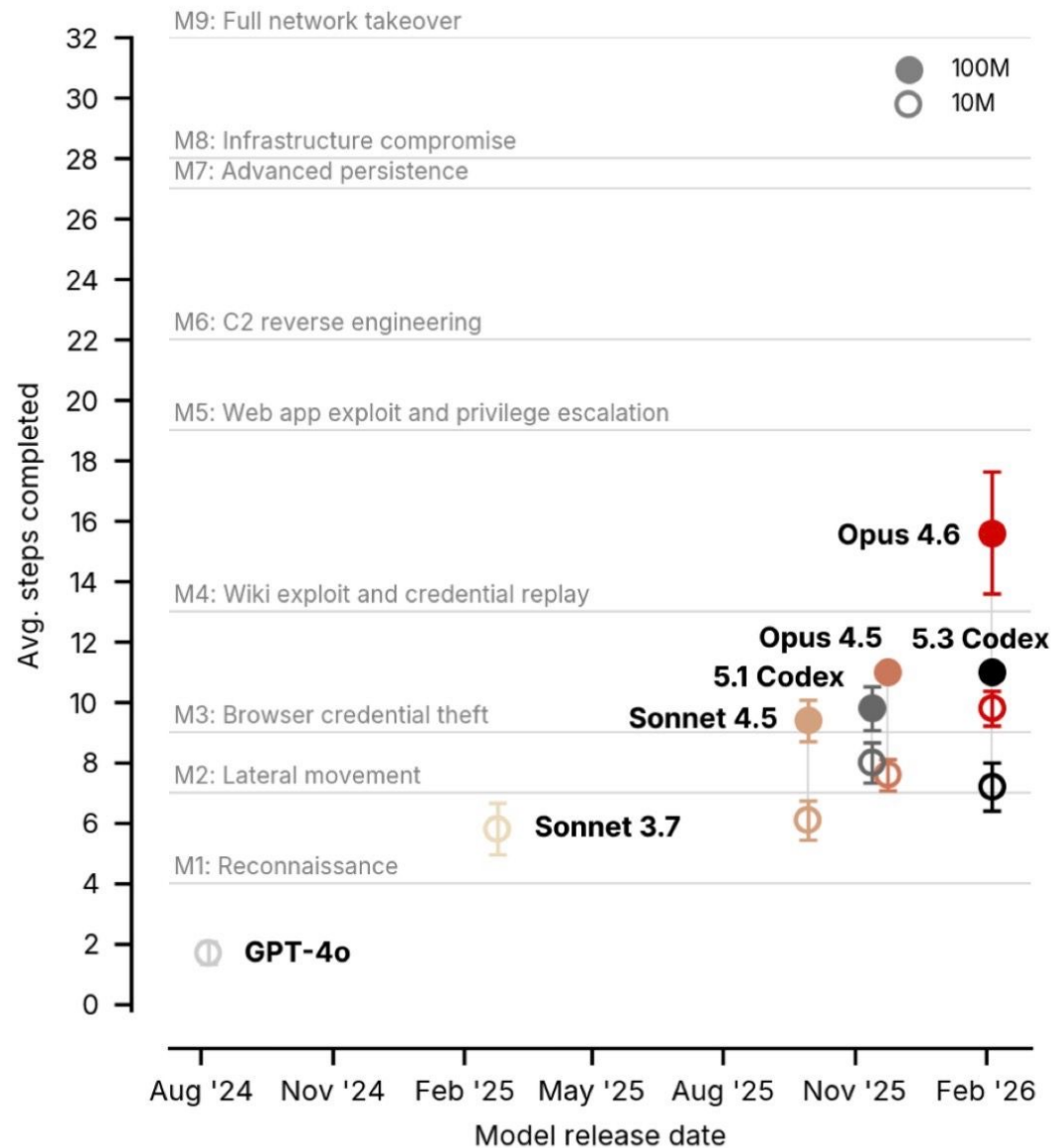
**Desde meados de
2023 que o ciber
espaço português tem
estado relativamente
“calmo”!**

**Embora estejamos
muito melhor
preparados, nunca
confiar na sorte!**

Com a rápida e crescente
utilização de **múltiplos Agentes**
IA na construção de estratégias
de ataque. É uma questão do
custo (***tokens***) que o atacante
está disposto em investir!

Com a rápida e crescente utilização de **múltiplos Agentes IA** na construção de estratégias de ataque.

É uma questão do custo (**tokens**) que o atacante está disposto em investir!



O *Ransomware* é pois uma ameaça real que exige uma ciber governança ativa! Diria mesmo “Proativa”!

Doutrina Ativa de Ciber Segurança

Doutrina Versus Regulamento

- Uma **DOCTRINA** é um sistema coerente, de referência de princípios, estabelecido por um indivíduo, instituição ou comunidade profissional. Uma **DOCTRINA** codifica crenças fundamentais, estratégias ou princípios orientadores dentro de um campo — seja ele militar, jurídico, acadêmico, religioso, político, ou, o nosso caso, da cibersegurança.
- Em todas as suas utilizações, a **DOCTRINA** funciona como um quadro conceptual organizador: ensina, unifica e fundamenta a ação com coerência e legitimidade.
- Uma **DOCTRINA** orienta as dimensões conceptuais e estratégicas da prática. Ela estabelece **porque e como** agir em termos gerais, oferecendo orientação sem prescrever em detalhe cada ação.
- Embora influenciem o comportamento e a tomada de decisões, uma **DOCTRINA** e um **REGULAMENTO** diferem em **natureza, autoridade, exequibilidade, flexibilidade, e finalidade**:

Característica	Doutrina	Regulamentação
<i>Natureza</i>	Princípios ou crenças de alto nível	Regras formais e explícitas ou requisitos legais
<i>Autoridade</i>	Orientação autoritária (por exemplo, militar, precedente legal)	Lei vinculativa — legislada ou oficialmente imposta
<i>Exequibilidade</i>	Seguido voluntariamente ou com orientação profissional; não vinculativo por si só.	Legalmente aplicável; a violação pode incorrer em penalidades
<i>Flexibilidade</i>	Interpretável e adaptável ao contexto	Prescritivo; normalmente fixo até ser formalmente alterado
<i>Finalidade</i>	Educa, proporciona consistência conceptual, define estratégias	Regulates activities to ensure standardized compliance and governance

**A Doutrina que propomos para a
Cibersegurança é particularmente
relevante na mitigação proativa
dos riscos de *Ransomware*!**

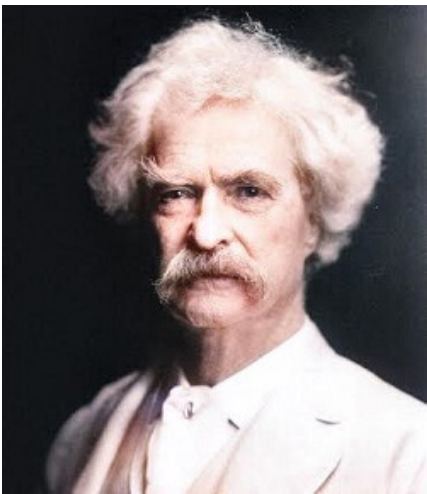
Tem em atenção a
“*Armadilha*” de
Mark Twain!



O Ciber crime tira partido do que eu apelidei da “**Armadilha**” de *Mark Twain*

*“It ain’t what you don’t know that gets you
into trouble. It’s what you know for sure
that just ain’t so.”*

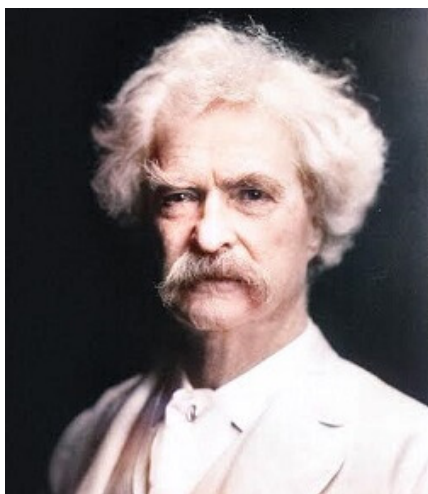
— Mark Twain



O Ciber crime tira partido do que eu apelidei da “*Armadilha*” de *Mark Twain*

*“It ain’t what you don’t know that gets you
into trouble. It’s what you know for sure
that just ain’t so.”*

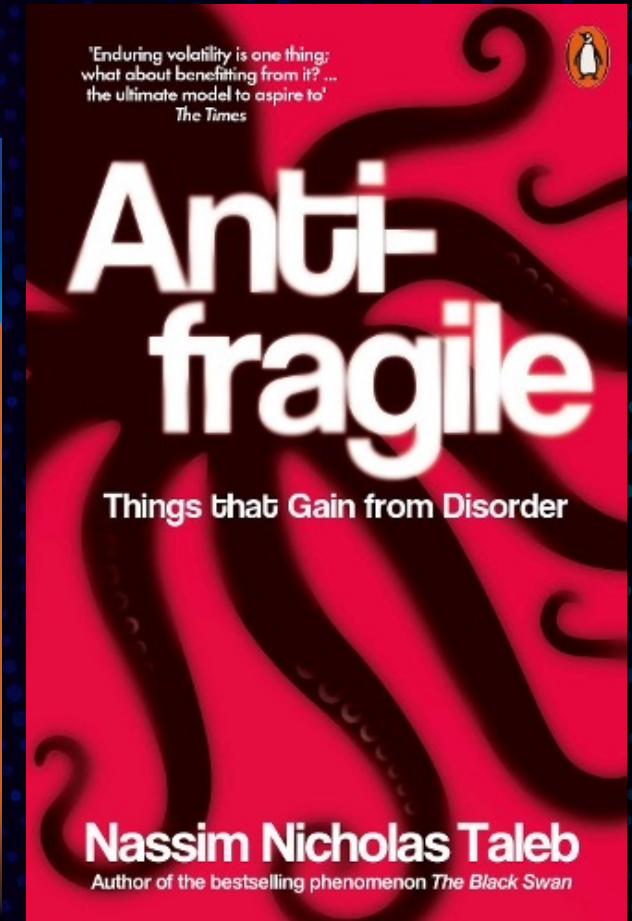
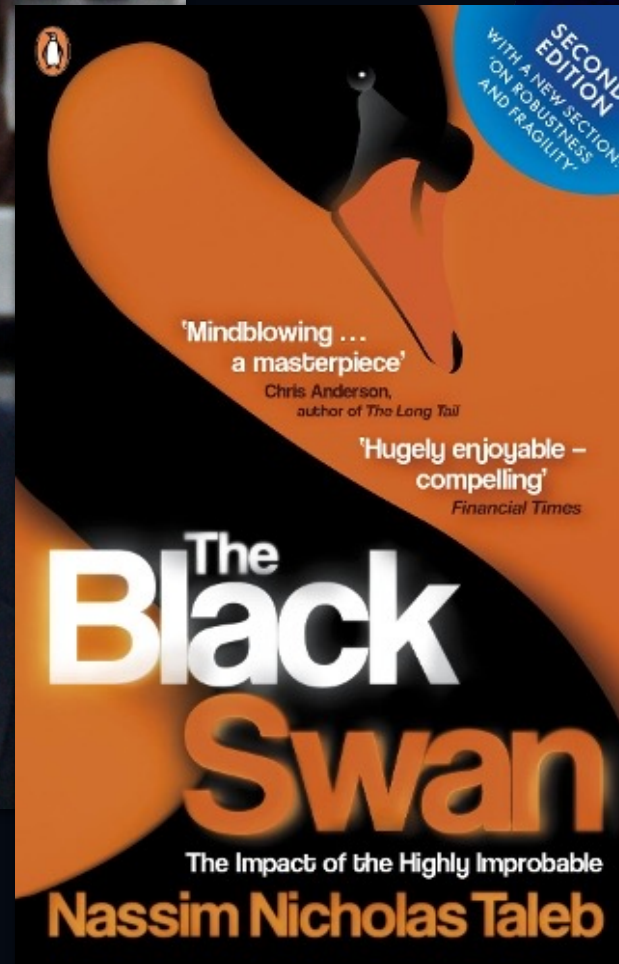
— Mark Twain



Cyber**security**.



E os ensinamentos de *Nassim Nicholas Taleb!*



1. É crítico desenvolver “**Antifragilidade**”, para além de “**Resiliência**”!
2. E estar minimamente preparado para eventos “**Black Swan**”!

As cinco dimensões de uma doutrina holística e proactiva de cibersegurança



Governança Holística e Proativa

- A **Governança Global** implica a existência efetiva da função **CISO**, com reporte direto ao poder executivo!
- Deve dispor dos meios necessários e suficientes para pro-ativamente **garantir, monitorizar, e supervisionar** as 5 dimensões da doutrina.
- Deve ser responsável pelo orçamento da Ciber Segurança, incluindo o necessário ao cumprimento da **NIS2**.
- Tem de assegurar...
 - Uma **Política de Segurança** eficaz para a organização.
 - As **métricas e indicadores** diários necessários à boa governança das 5 dimensões da doutrina.
 - Um **Comité de Segurança**, c/ a gestão de topo, com reuniões semestrais de acompanhamento.
 - E, finalmente, tem de obviamente assegurar o cumprimento da lei (e.g., **NIS2**) e demais regulamentos.

Importância de uma Governança Holística e Proativa

- A **Governança holística** e **proativa** é vital para mitigar os riscos e resolver as vulnerabilidades antes que estas se agravem.
- Um **CISO** não deve apenas reagir a incidentes, mas tem principalmente de implementar estratégias que antecipem e previnam potenciais ameaças à segurança, garantindo, de forma contínua, a integridade e a resiliência da organização.

Um bom CISO deve ser...

- Tecnicamente competente!
- De sangue frio! Sereno, racional e resiliente sob pressão!
- Emocionalmente inteligente e bom comunicador!
- Com mente analítica, focada numa ciber governança racional, baseada num sistema de métricas confiáveis, que ele próprio deve garantir, orientadas a uma análise situacional e melhoria contínua!
- Um bom estudante do mundo da ciber criminologia, da armadilha de Mark Twain, dos ensinamentos de Nassim Nicholas Taleb, e participante ativo em redes de contactos envolvendo os principais CSIRTs nacionais e internacionais, forças de segurança ligadas ao ciber crime e à ciber inteligência, ...

Principais Desafios?

1. Encontrar um bom **CISO** é talvez o primeiro e principal desafio a ultrapassar. Felizmente que em organizações de dimensão média ou pequena a função **CISO** pode ser exercida a tempo-parcial.
2. Desenvolver “**Antifragilidade**”, para além de “**Resiliência**”!
3. E estar minimamente preparado para eventos “**Black Swan**”!

Prevenção Ativa



- A **Prevenção Ativa** deve garantir medidas que minimizem a probabilidade de um ataque se poder iniciar (*medidas inibidoras*).
- Deve cobrir seis subdimensões:
 1. Sistemas expostos à **Internet**,
 2. Sistemas **Internos**,
 3. Sistemas da **Cadeia de Abastecimento**,
 4. Sistemas de **Segurança**,
 5. Processos de Desenvolvimento de **Aplicações** e **Scripts**, e
 6. Utilizadores (**Pessoas**).
- Deve garantir, de forma contínua, ...
 - Uma elevada *ciber higiene* de todos os ativos relevantes,
 - Uma elevada *sensibilização* à ciber segurança de todos os utilizadores (internos e externos). *Minimização da sua ingenuidade* face a comunicações e sítios maliciosos.
 - Processos e tecnologias de *gestão e mitigação inteligente de vulnerabilidades*, especialmente para os activos direta ou indiretamente expostos a ameaças.

- A **Prevenção Ativa** deve garantir medidas que minimizem a probabilidade de um ataque se poder iniciar (*medidas inibidoras*).
- Deve cobrir seis subdimensões:

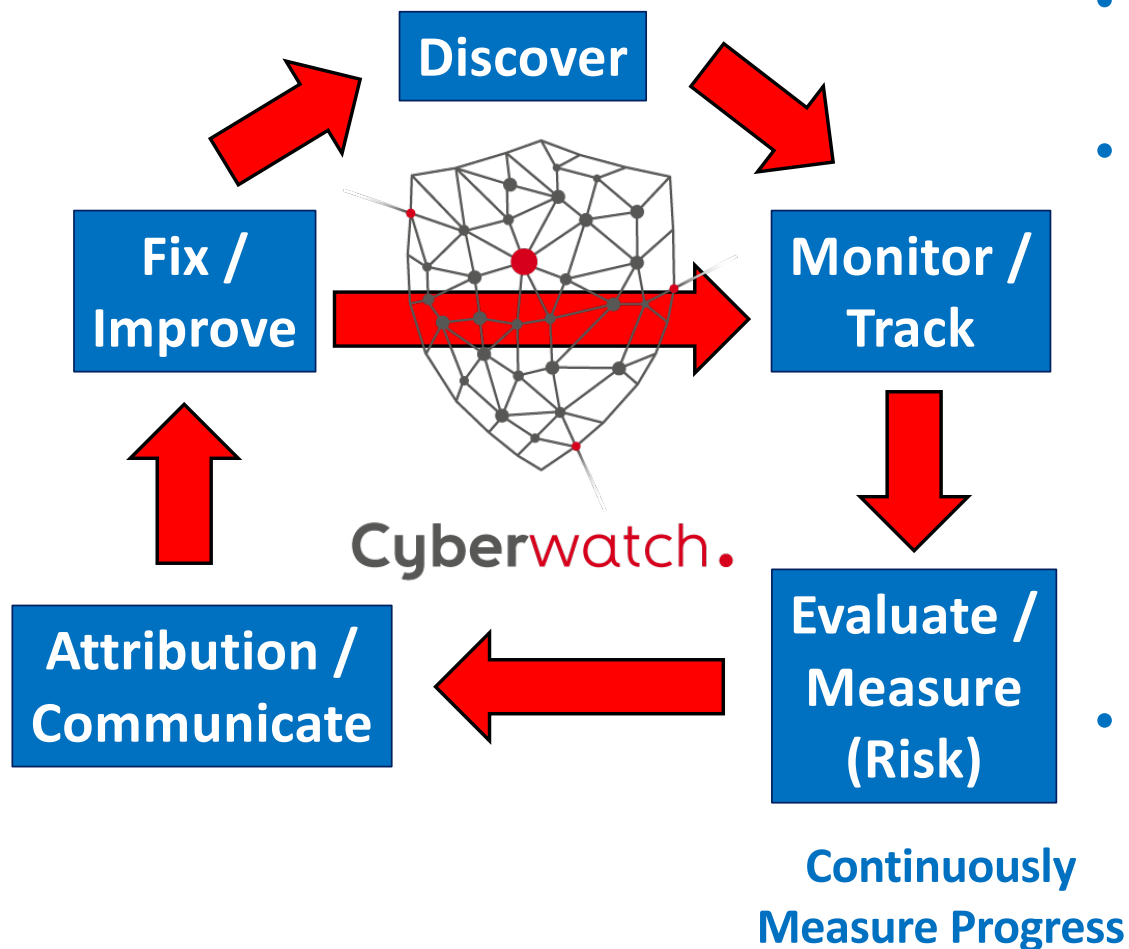
1. Sistemas expostos à Internet

Elementos Mínimos:

- Manter sistemas atualizados → *Minimizar a sua **OBSOLESCÊNCIA!***
- Reduzir a exposição direta à Internet → *Minimizar a **SUPERFÍCIE DE ATAQUE!***
- Manter elevados níveis de **CIBER HIGIENE** (elevado **BITSIGHT** rating!) especialmente nos sistemas com exposição à Internet e nos sistemas críticos!
- Garantir **MÉTRICAS** diárias relevantes da **CIBER HIGIENE** de todos os ativos!

Processos e tecnologias de gestão e mitigação inteligente de vulnerabilidades, especialmente para os activos direta ou indiretamente expostos a ameaças.

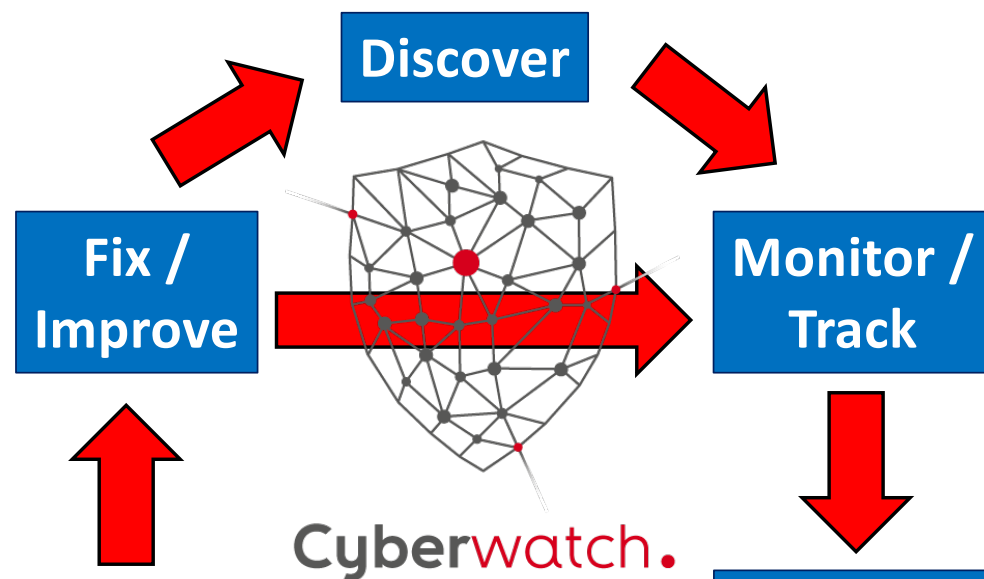
Ciber Higiene: Monitorização Contínua



- Equipe dedicada à manutenção ativa e contínua da CIBER HIGIENE!
- Ferramentas usadas continuamente:



- Periodicamente:
 - Pen Testing (*especialistas externos*)



- Equipe dedicada à manutenção ativa e contínua da CIBER HIGIENE!
- Ferramentas usadas continuamente:

BIT SIGHT
The Standard in SECURITY RATINGS

SpyCloud

CYCOGNITO

QUALYS

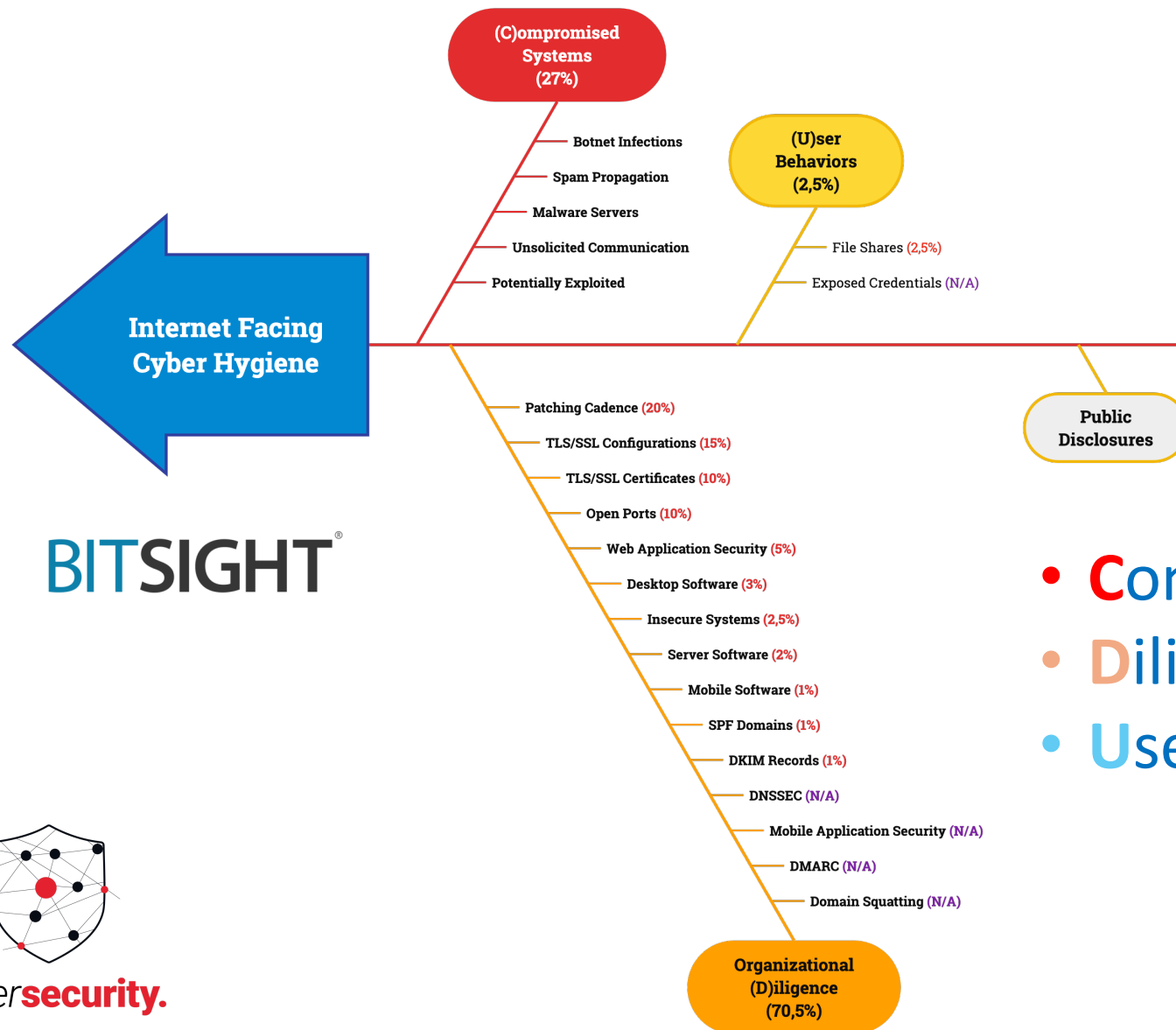
Probely

Desafio: *As equipes técnicas não conseguem aplicar todos os corretivos de segurança dentro dos prazos necessários!*

Ciber Higiene:



Ishikawa Diagram



- **C**ompromised Systems
- **D**iligence (Technical)
- **U**ser Behavior

Categories of risk.

Bitsight categorizes cyber risk data into four primary categories as part of the collection and verification process.



Compromised Systems

Indicates the presence of malware or unwanted software, which is evidence of security controls failing to prevent malicious or unwanted software from running within an organization.

27%



Organizational Diligence

Externally observable data about how servers and records in an organization are configured and provides insight into the security hygiene of an organization.

70,5%



User Behaviors

Employee activities that may introduce risks into an organization's networks, such as sharing files over BitTorrent and determining if employees are re-using corporate login credentials outside of the corporate network.

2,5%



Public Disclosures

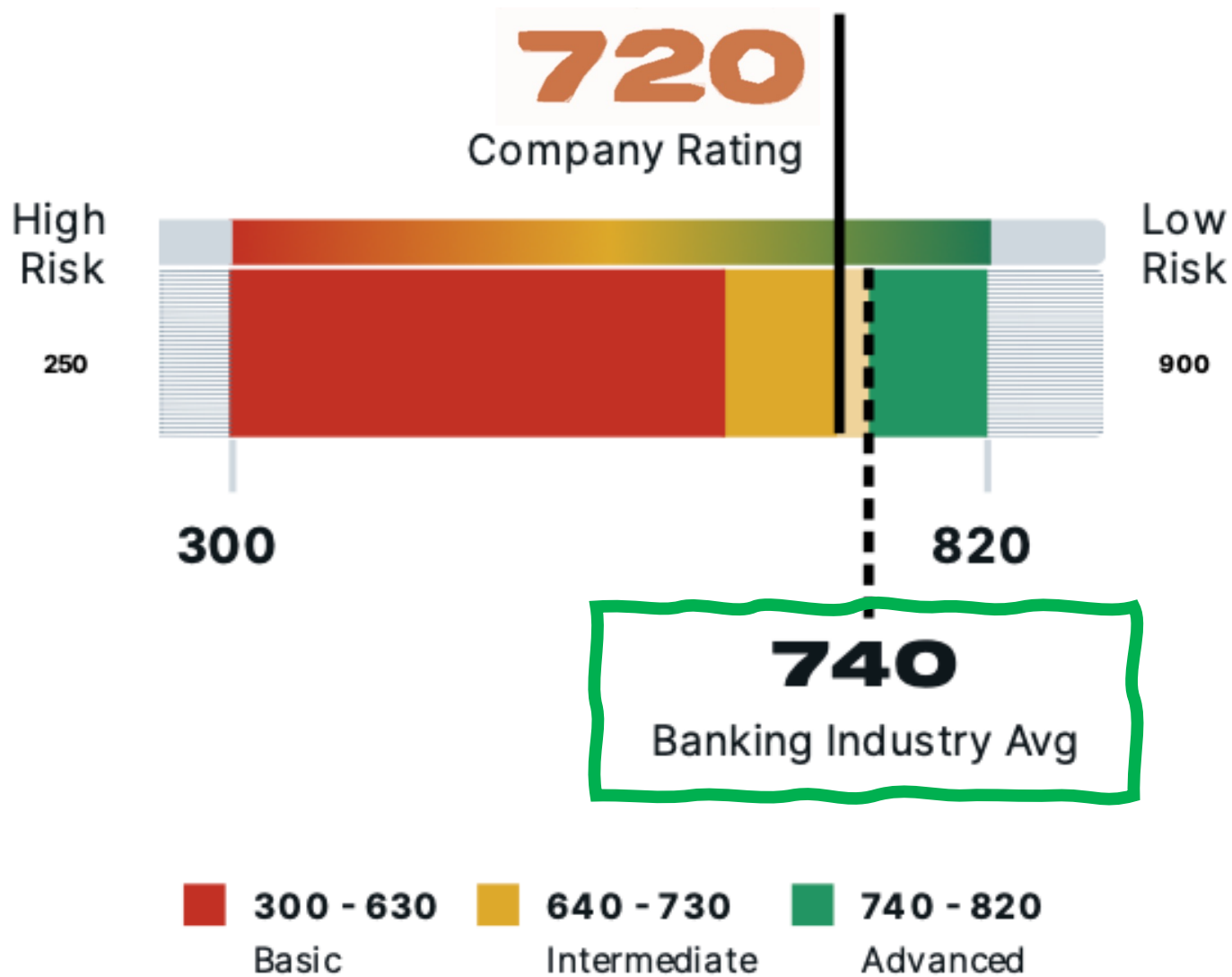
Information related to possible incidents of undesirable access to a company's data, including breaches, general security incidents, and other disclosures.

N/A

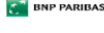
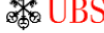


Classificações de Risco da BitSight

- **250–639:** Mitigação básica de riscos cibernéticos.
- **640–739:** Mitigação intermediária.
- **740–900:** Mitigação avançada.



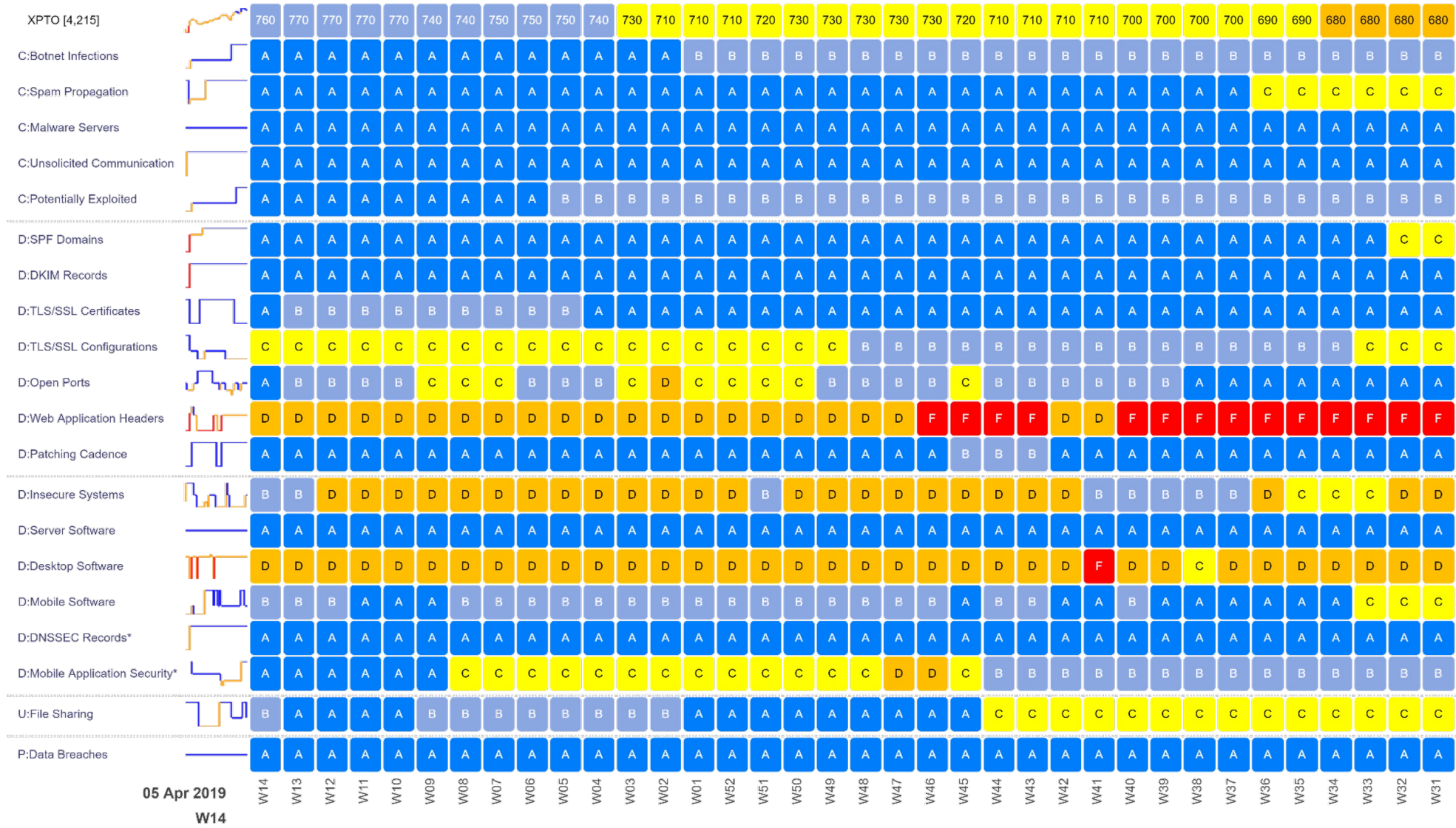
Company		Trend	Rating
 ABN-AMRO	ABN AMRO Group		800
 CaixaBank	CaixaBank, S.A. Group		800
 SOCIETE GENERALE	Societe Generale Group Corporate...		770
 DZ BANK	DZ BANK Group		750
 La Banque Postale	La Banque Postale Group		740
 LLOYDS BANKING GROUP	Lloyds Banking Group of Companies		730
 COMMERZBANK	Commerzbank Group		720
 GROUPE BPCE	Groupe BPCE		710
 INTESA SANPAOLO	Intesa Sanpaolo Corporation -...		710
 Rabobank	Coöperatieve Rabobank Group		680
 GROUPE CREDIT AGRICOLE	Crédit Agricole Group		670
 Nordea	Nordea Bank Group of Companies		670
 Deutsche Bank	Deutsche Bank Corporation		630

Company		Trend	Rating
 Santander	Banco Santander S.A.		800
 UniCredit	UniCredit Banking Group – UniCredit		780
 BNP PARIBAS	BNP Paribas Group		760
 Crédit Mutuel	Crédit Mutuel - Activités bancaires...		740
 Danske Bank	Danske Bank Group		730
 BARCLAYS	Barclays Corporation		720
 NatWest	NatWest Group of Companies		720
 ING	ING Groep N.V.		710
 BBVA	BBVA Group		690
 standard chartered	Standard Chartered Bank Group		680
 HSBC	HSBC Group		670
 UBS	UBS AG Group		660

Análise Situacional

Exemplo de Heatmap Normalizado

Global Cyber Hygiene BITSIGHT Rating for XPTO [4,215]





10-16-2018 at 16:30

Details

i Certificate Valid: 06-12-2017 – 06-13-2022

i Key Length (bits): 2048

Key Algorithm: RSA

Signing Algorithm: SHA1WITHRSA

i Issuer: CN=PTPLSBCAS02

Subject: CN=PTPLSBCAS02

i Subject Alternate Names:

[illegible]

Issue

Remediation Instructions

Allows insecure protocol:

Update your company servers configurations

Attribution!

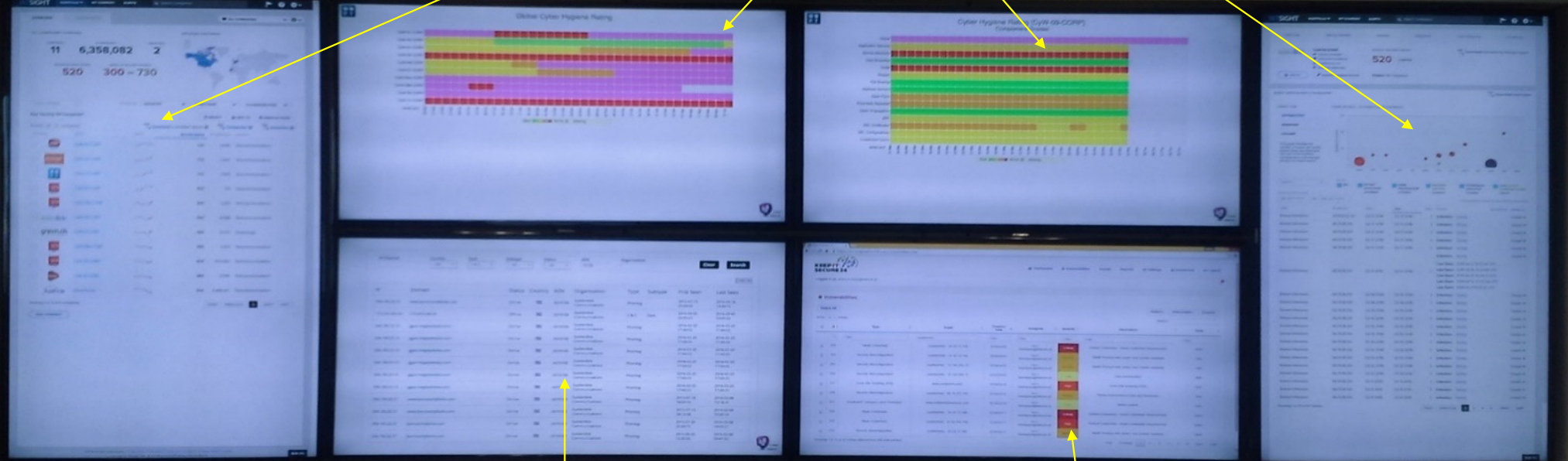
Cybersecurity.



"It ain't what you don't know that gets you into trouble.
It's what you know for sure that just ain't so."
Mark Twain



Cyber Hygiene Observatory



Threats

Vulnerabilities

A SEGURANÇA COMEÇA EM SI.



	Governance	C	Compromised
	Inhibitor	D	Diligence
	Counter Response	U	User Behavior
	Last Defense	P	Public Disclosures

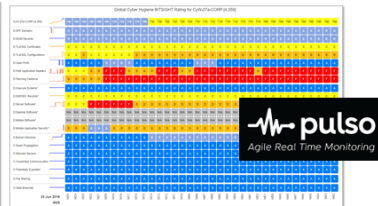
Backup Resilience	Weights
D: CyberHygiene	50,0%
D: Resilience	50,0%

CyberSOC Capability	Weights
D: Ingress / Egress Coverage	15,0%
D: Other Net & NIDS Coverage	15,0%
D: Windows EndPoint Coverage	10,0%
D: Windows Server Coverage	10,0%
D: Non Windows Coverage	10,0%
D: Backup Infrastructure Coverage	10,0%
D: CyberIntel Capability	10,0%
D: Automation Level	10,0%
D: Internal SLA	10,0%

Architecture Resilience	Weights
D: Outer Defense Resilience	15,0%
D: DNS Resilience	15,0%
D: NTP Resilience	5,0%
D: Anti DDoS Capability	15,0%
D: Critical Backups in Windows?	10,0%
D: Internal Nets Homogeneity	10,0%
D: NAC Capability	10,0%
D: RED BREAK Capability	10,0%

Governance Capability	Weights
D: Shared Objectives in Place?	15,0%
D: Security Risk Mgmt in Place?	15,0%
D: CyberWatch+ Coverage	15,0%
D: Beware! Coverage	10,0%
D: RED Wall Policies Coverage	10,0%
D: IDAccess Coverage	10,0%
D: RED Gate Coverage	10,0%
D: RED Break Coverage	5,0%
D: RED Alert Coverage	10,0%

CyberHygiene:EXTERNAL	Weights
C: Botnet Infections	11,0%
C: Spam Propagation	11,0%
C: Malware Servers	11,0%
C: Unsolicited Communication	11,0%
C: Potentially Exploited	11,0%
D: SPF Domains	1,0%
D: DKIM Records	1,0%
D: TLS/SSL Certificates	5,0%
D: TLS/SSL Configurations	5,0%
D: Open Ports	13,0%
D: Web Application Headers	3,0%
D: Patching Cadence	2,0%
D: Insecure Systems	1,0%
D: Server Software	2,0%
D: Desktop Software	1,5%
D: Mobile Software	0,5%
D: DNSSEC *	
D: Mobile Application Security*	
D: Domain Squatting**	
U: File Sharing	10,0%
U: Exposed Credentials**	
P: Breaches	
P: Other Disclosures	



Network Assets:Managed	Weights
D: Obsolescence	10,0%
D: Security Patching	10,0%
D: Open Ports	20,0%
D: Info Quality	10,0%
C: Delivery & Attack	9,0%
C: Environmental Awareness	9,0%
C: Exploitation & Installation	9,0%
C: Reconnaissance & Probing	9,0%
C: System Compromise	14,0%

EndPoints:Managed	Weights
D: Obsolescence	5,0%
D: AV Update	10,0%
D: Security Patching	25,0%
D: Open Ports	5,0%
D: RED Proxy Compliance	10,0%
D: RED Wall Compliance	10,0%
D: RED Alert Compliance	5,0%
C: Environmental Awareness	5,0%
C: Exploitation & Installation	5,0%
C: Reconnaissance & Probing	5,0%
C: System Compromise	5,0%

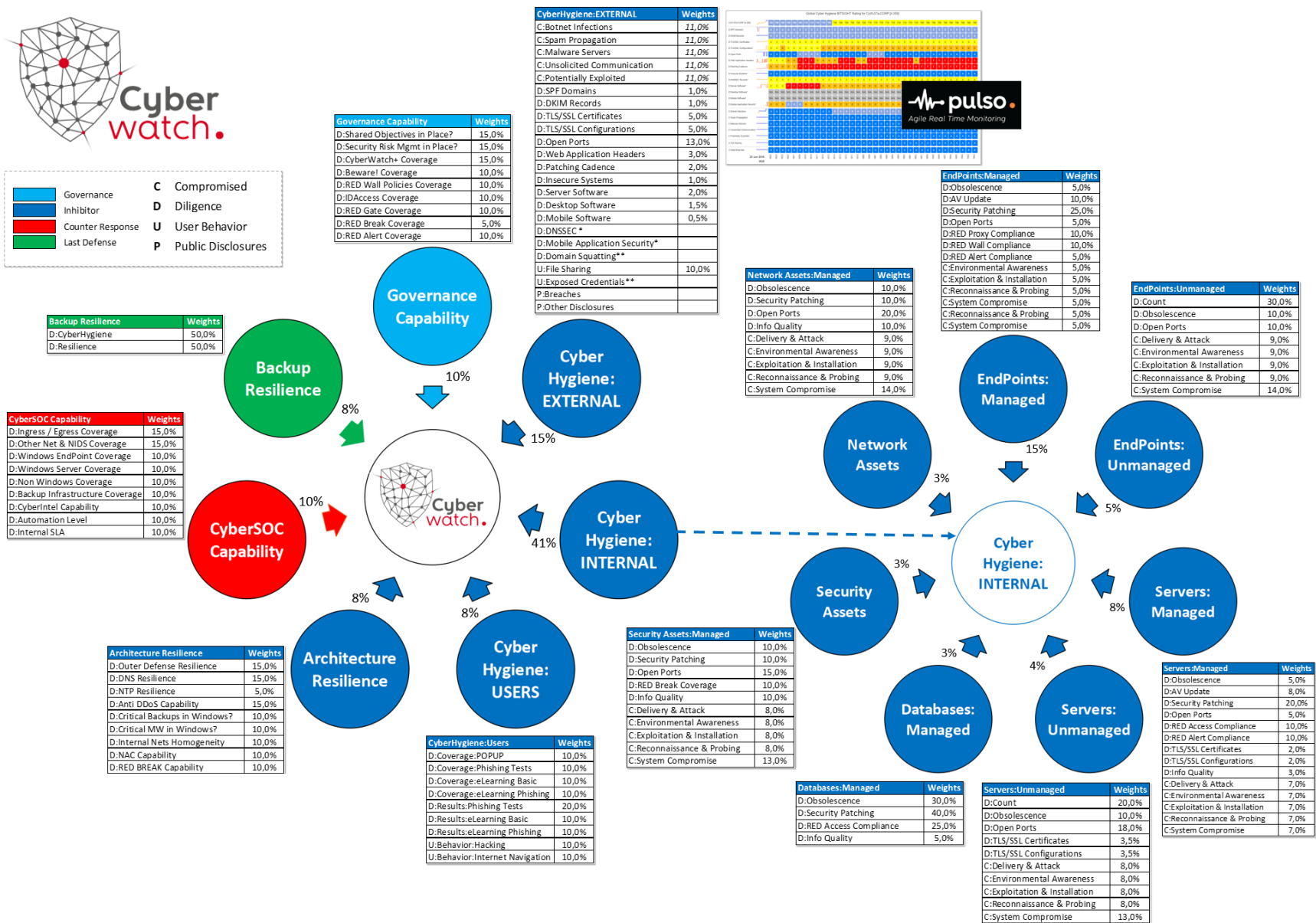
EndPoints:Unmanaged	Weights
D: Count	30,0%
D: Obsolescence	10,0%
D: Open Ports	10,0%
C: Delivery & Attack	9,0%
C: Environmental Awareness	9,0%
C: Exploitation & Installation	9,0%
C: Reconnaissance & Probing	9,0%
C: System Compromise	14,0%

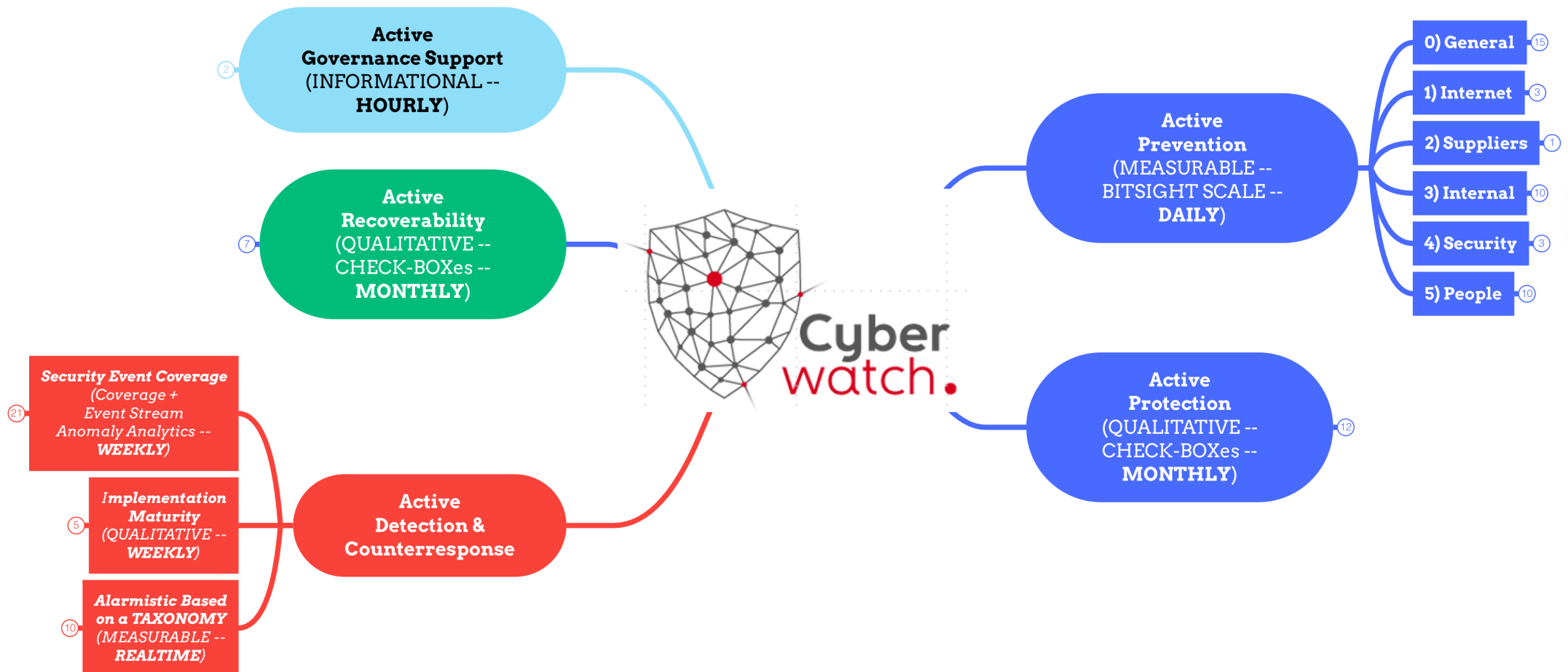
Security Assets:Managed	Weights
D: Obsolescence	10,0%
D: Security Patching	10,0%
D: Open Ports	15,0%
D: RED Break Coverage	10,0%
D: Info Quality	10,0%
C: Delivery & Attack	8,0%
C: Environmental Awareness	8,0%
C: Exploitation & Installation	8,0%
C: Reconnaissance & Probing	8,0%
C: System Compromise	13,0%

Databases:Managed	Weights
D: Obsolescence	30,0%
D: Security Patching	40,0%
D: RED Access Compliance	25,0%
D: Info Quality	5,0%

Servers:Unmanaged	Weights
D: Count	20,0%
D: Obsolescence	10,0%
D: Open Ports	18,0%
D: TLS/SSL Certificates	3,5%
D: TLS/SSL Configurations	3,5%
C: Delivery & Attack	8,0%
C: Environmental Awareness	8,0%
C: Exploitation & Installation	8,0%
C: Reconnaissance & Probing	8,0%
C: System Compromise	13,0%

Servers:Managed	Weights
D: Obsolescence	5,0%
D: AV Update	8,0%
D: Security Patching	20,0%
D: Open Ports	5,0%
D: RED Access Compliance	10,0%
D: RED Alert Compliance	10,0%
D: TLS/SSL Certificates	2,0%
D: TLS/SSL Configurations	2,0%
D: Info Quality	3,0%
C: Delivery & Attack	7,0%
C: Environmental Awareness	7,0%
C: Exploitation & Installation	7,0%
C: Reconnaissance & Probing	7,0%
C: System Compromise	7,0%



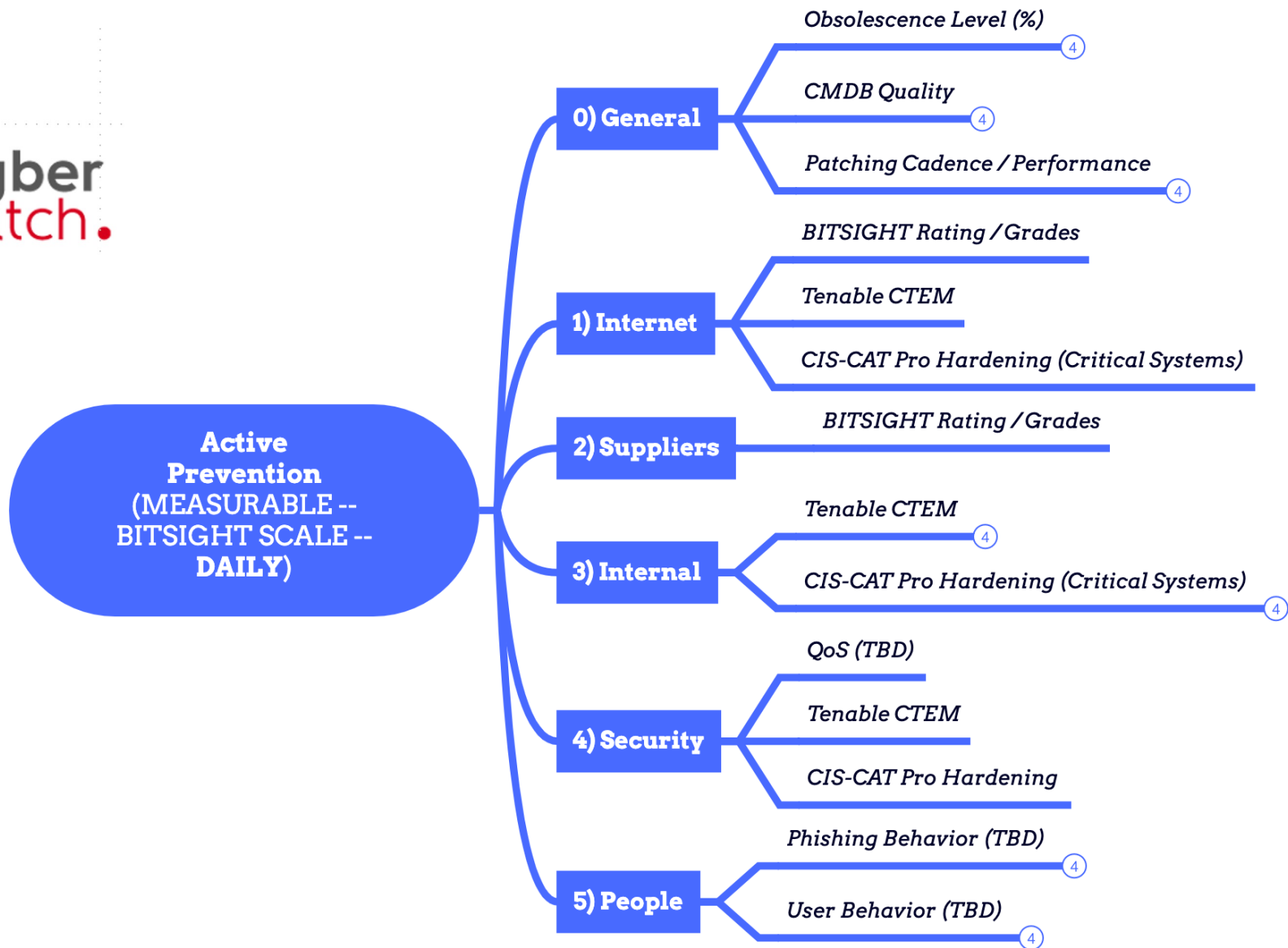


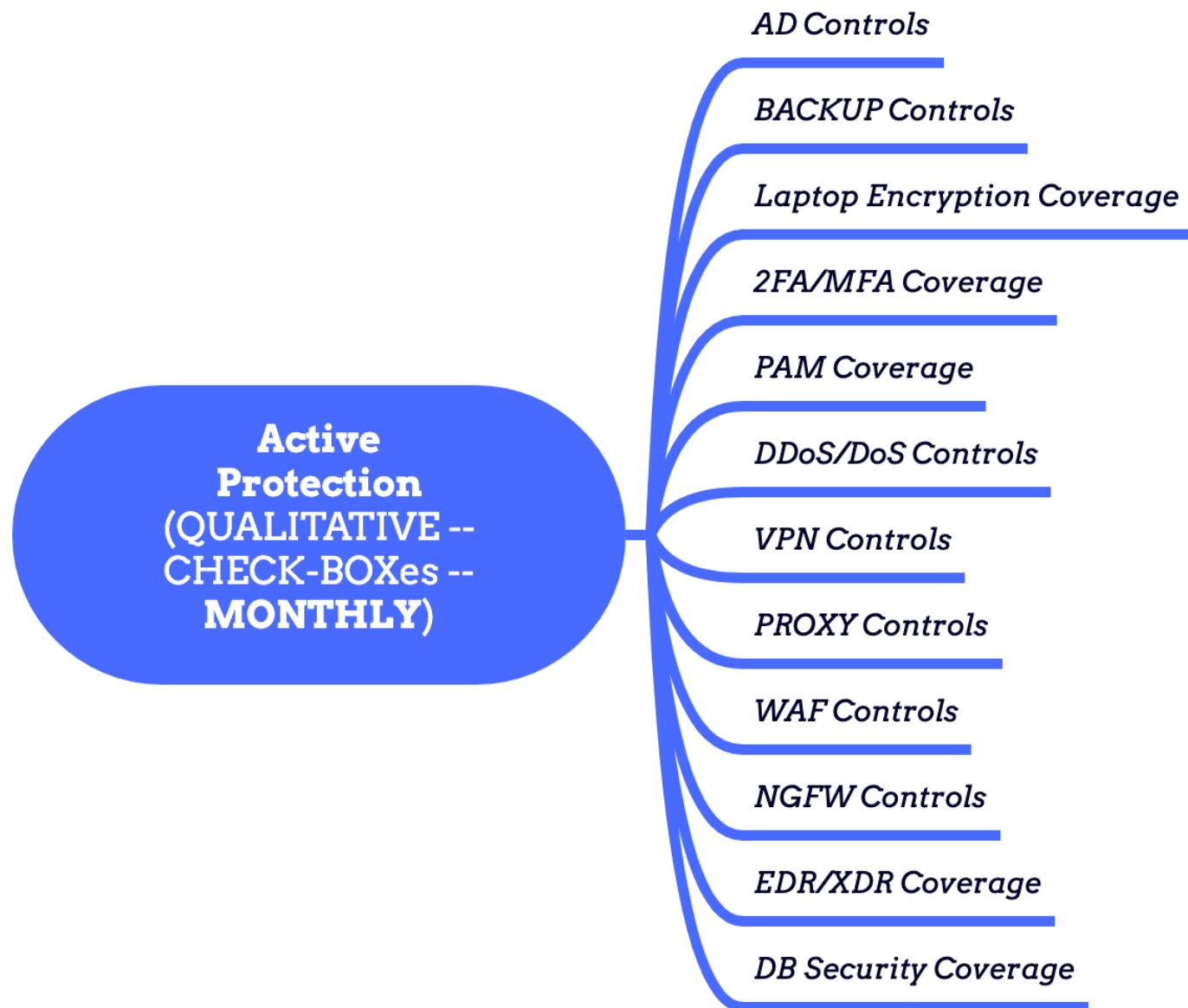


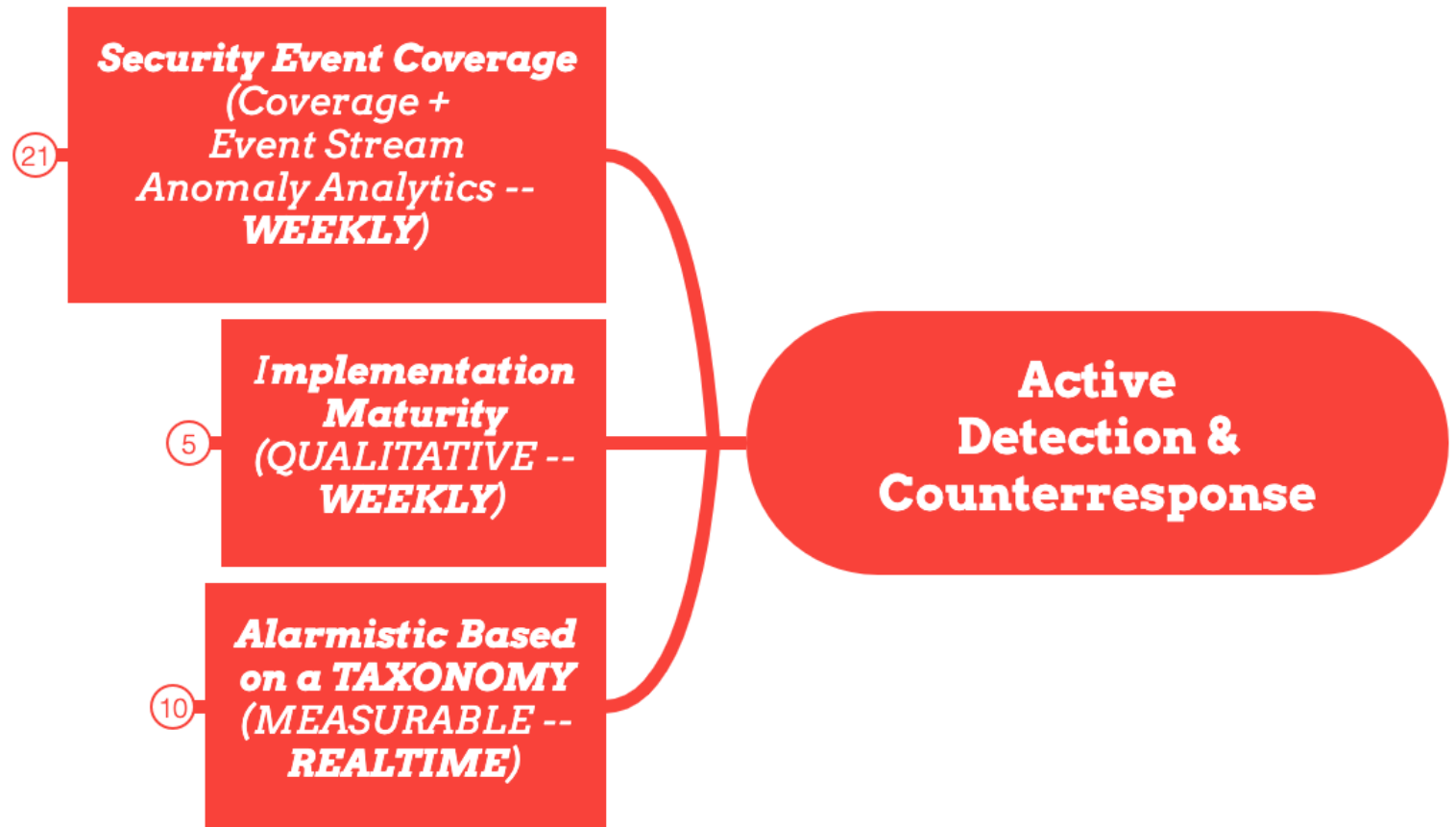
*Threat Environment
(Recorded Future)*

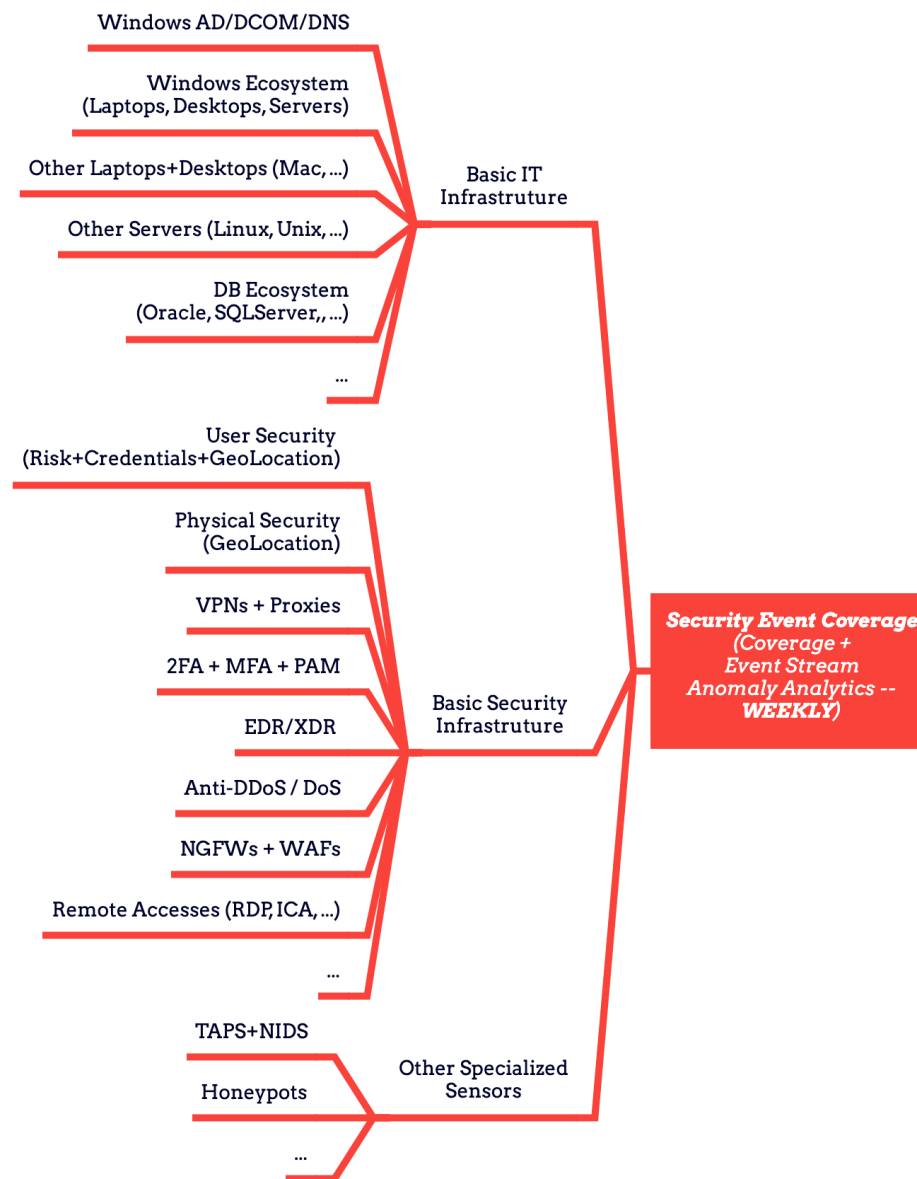
...

**Active
Governance Support
(INFORMATIONAL --
HOURLY)**











Threat Intel Streams Maturity

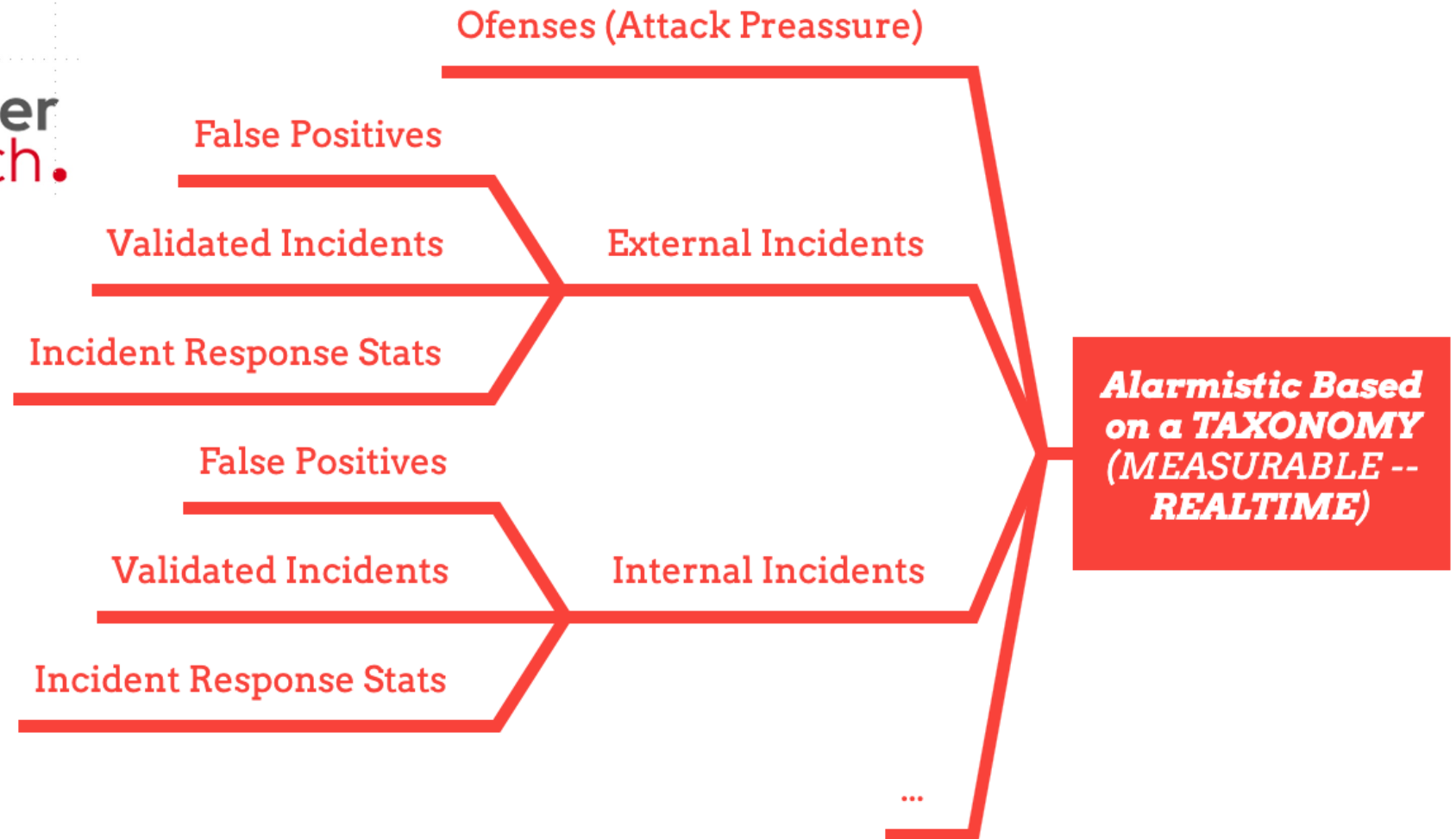
SIEM Event Correlation Maturity

UEBA Event Correlation Maturity

SOAR Playbook Maturity

AI Based Automation Maturity

***Implementation
Maturity
(QUALITATIVE --
WEEKLY)***





Security Team Tech Heterogeneity

AD Recoverability (SEMPERIS)

BACKUP recoverability

SW Distribution Recoverability

VPN Recoverability

Proxy Recoverability

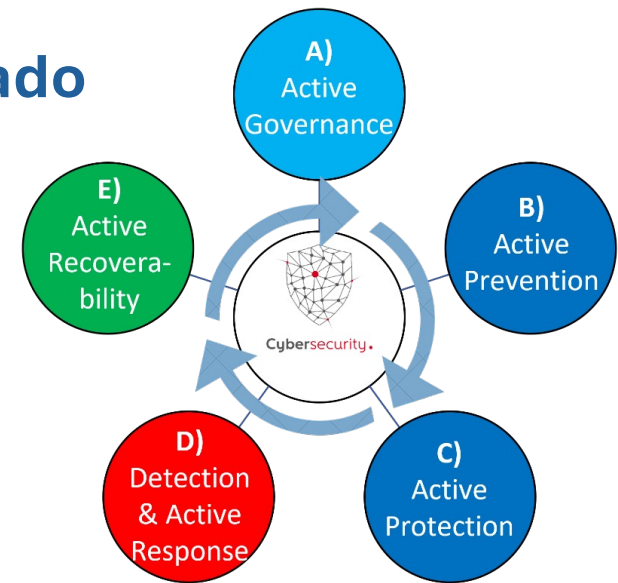
...

**Active
Recoverability
(QUALITATIVE --
CHECK-BOXes --
MONTHLY)**

Propriedades chave de um Sistema analítico orientado à “Análise Situacional” da Ciber Segurança:

- Deve suportar a **GOVERNANÇA ATIVA**
- Tem de ser o **PAINEL OFICIAL INFORMACIONAL** usado na comunicação com todos os “*stakeholders*” relativamente à Ciber Segurança!
- Deve ser **360°**: e cobrir as 5 dimensões da **DOCTRINA ATIVA**!
- Todas as métricas devem ser **PRÉ-NORMALIZADAS**! Para o efeito, uso, como referência, a escala da **BITSIGHT** [**250** → **900**]!
- Deve integrar com a plataforma corporativa de gestão de risco, como a **OneTrust**, **Eramba** ou **GlobalSuite Solutions**
- Deve suportar um processo racional, auditável de melhoria contínua da gestão do risco de ciber segurança.
- Finalmente, deve permitir ilustrar o impacto dos investimentos feitos:

Estamos hoje melhor do que ontem? Porquê? Porque não?



Principais Desafios?

1. Garantir processo semi-automático de manutenção da **CMDB** (*Configuration Management Database*).
2. Garantir “*agentes inteligentes*” que suportem:
 - A análise situacional contínua com base nas métricas no CyberWatch – múltiplas séries temporais normalizadas (escala *BITSIGHT*), temporalmente alinhadas (UTC) mas com pontos de medida com diferentes ciclos (*segundo → hora → dia → semana → mês*)! Garantir **REPORTS** e **ALARMES** para o **CISO** e sua equipe.
 - A priorização dos processos de aplicação de “*patching de segurança*” tendo em conta a gestão do risco real, das dependências técnicas dos ativos a atualizar e da produtividade real das equipes técnicas.
 - A execução apoiada desses **processos corretivos**!
3. E, finalmente, ter em conta a necessidade de desenvolver **Antifragilidade** na organização!

Proteção Ativa



- Uma estratégia de **Proteção Ativa** é essencial para garantir a contenção de ataques eventualmente já iniciados. Deve reduzir a probabilidade de um ataque se propagar (*medidas inibidoras*).
- Deve procurar garantir:
 - Sistemas em Datacenter seguro c/ mecanismos anti DDoS e WAF.
 - Rede corporativa segmentada + NGFWs envolvendo pelo menos dois “brands”
 - Diversidade tecnológica em zonas chave! Regra dos 90 x 10!
 - Contra verificação universal nos acessos: *2FA/MFA universal e PAM para sistemas críticos*
 - VPN e Internet Proxy únicas, obrigatórias, centralizadas e seguras
 - Sistema seguro de *email + messaging*
 - Solução EDR/XDR em todos os ativos computacionais (“end-points”).
 - Especial atenção à segurança da AD / Entra-ID, BACKUPS e “Crown Jewells”.

Elementos Mínimos:

- Manter sistemas em **Data Center profissional**, confiável e com mecanismos anti **DDOS** e **WAF**!
- Evitar redes corporativas sem segmentação e 100% uniformes!
- Garantir sistema universal de **2FA/MFA**! Sem exceções!
- Garantir pontos seguros e monitorizáveis de acesso à rede corporativa (**VPN**) e de acesso à Internet (**Proxy**)
- Sistemas seguros de *email e messaging*
- Garantir solução **EDR/XDR** para todos os dispositivos: laptops/desktops, servidores, smartphones.
- Proteção especial à **AD + BACKUPS + “Crown Jewells”**.
- Garantir **métricas e indicadores** relevantes!

Principais Desafios?

A. Desenvolver “agentes inteligentes” que suportem:

1. A detecção de **falhas** e/ou **comportamentos anómalos** na arquitetura de segurança → Eliminar causas de eventuais **falsos negativos**!
2. A detecção de “**black holes**” na arquitetura de segurança.
3. A orquestração de todos os elementos ativos da arquitetura de segurança (VPN, Proxy, NGFWs, ...).

B. Garantir processos de melhoria contínua e de **antifragilidade**.

C. Finalmente, garantir base mínima para lidar com eventuais eventos “**Black Swan**”.

Detecção e Contra Resposta Ativa



Realtime

Relevant Security Events

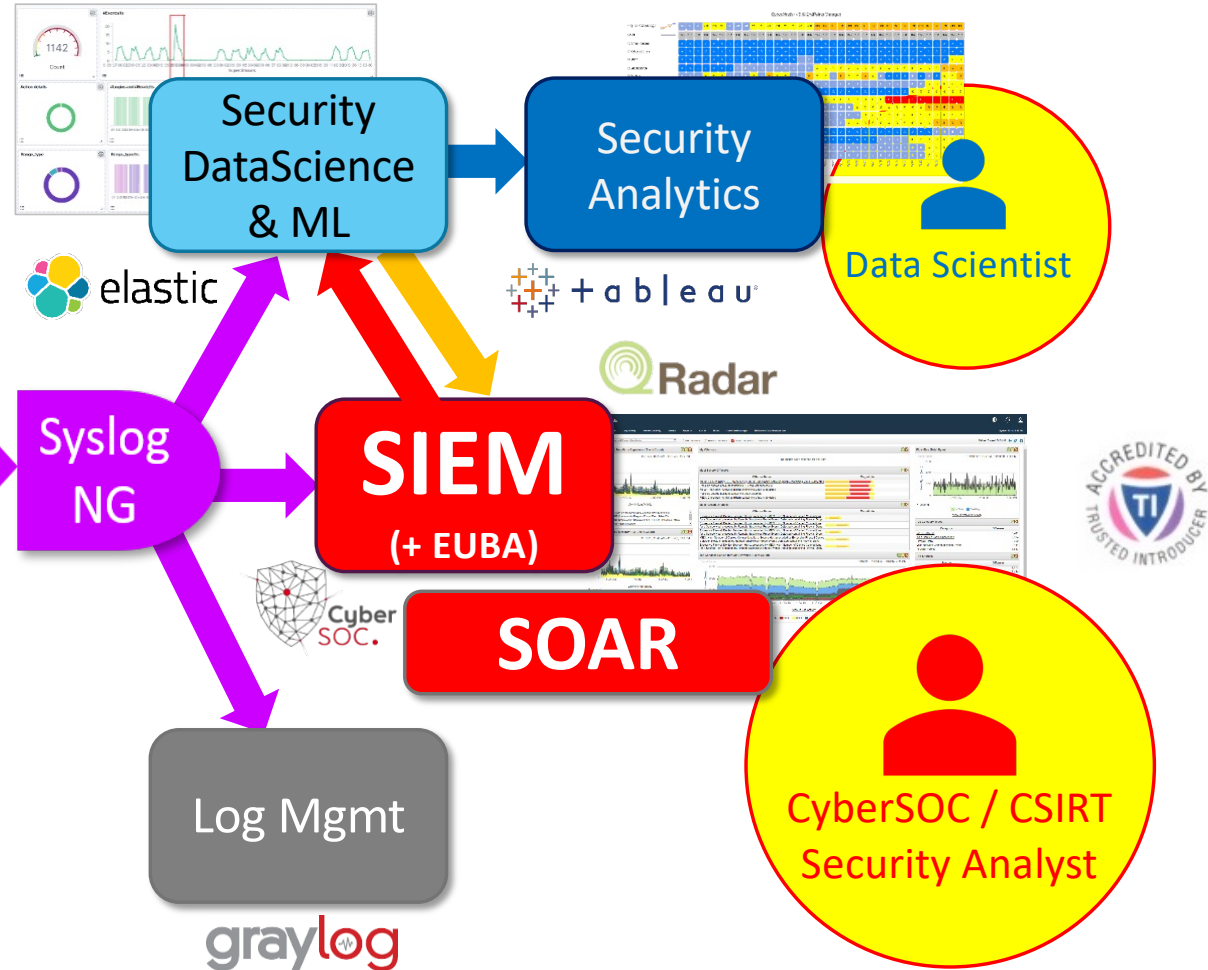
- Windows AD & DCOM NS
- Windows Ecosystem (Supercharger)
- Other Endpoints (Mac, ...)
- Other Servers (Linux, Unix, ...)
- Data (IBM Guardium)
- Physical Security
- NG Firewalls (Cisco, CheckPoint, Fortinet, ...)
- Remote Accesses + VPNs (CheckPoint VPN, CITRIX, A10 T, ...)
- Proxies (zScaler, ...)
- Anti-DDoS (Networks, Allot)
- Other Security Controls (Swivel, CyberArk, Extreme NAC, Sandblast, ...)
- EDR/XDR (CrowdStrike Falcon)
- Network Monitoring & Services (BGPMON)
- TAPS+NIDS (Suricata)
- Honeypots (Canaries)

Basic Infrastructure

Security Infrastructure

Additional Sensors

Security Events



- A deteção atempada, identificação e respetiva contrarresposta eficaz a tentativas de ciber ataques é crucial para lidar com ciber incidentes.
- A utilização de sistemas de monitorização avançados permite a rápida identificação de ameaças e a capacidade de responder prontamente, minimizando os potenciais danos.
- Esta é a principal responsabilidade de um **SOC**.
- Detetar, em tempo útil, ataques que tentam ser furtivos é um desafio que tem de ser vencido!
- Investimento forte na automação inteligente dos processos de deteção e contrarresposta.

Elementos Mínimos:

- Garantir um **serviço profissional SOC** (*Security Operations Center*) com suporte à mitigação de incidentes de cibersegurança!
- Garantir a **monitorização** de todos os ativos relevantes:
 - Toda a rede corporativa e seus ativos;
 - 2FA/MFA, PAM, VPN e Proxy Internet;
 - AD e sistemas de BACKUP;
 - Todos os sistemas de segurança (firewalls, ...);
 - Integração com plataforma **EDR/XDR**!
 - E **“honeypots”** em pontos estratégicos!
- Garantir integração de **“Cyber Intelligence Feeds”** relevantes!
- Garantir processos confiáveis e automatizados de **deteção e contrarresposta**!
- Garantir **métricas** relevantes cobrindo: *Ataques, incidentes, mitigações e funcionamento do próprio SOC.*

Principais Desafios?

1. Determinar o que pode ser contrarrespondido de forma **100% automática** ou não (*Lei de Pareto*).
2. Facilitar os processos contínuos de redução de **falsos positivos e falsos negativos**.
3. Maximizar a produtividade efetiva do **SOC**!
4. Garantir métricas que reflitam essa evolução, ou não!

Recuperação Ativa



Business Resilience



- A capacidade de recuperação como última defesa garante que uma organização pode **restaurar as operações** após um incidente.
- **Resiliência** não é **Recuperação**! É sim o que nos permite continuar a operar enquanto a Recuperação prossegue.
- Um plano prático de recuperação envolve cópias de segurança de dados, equipas e resposta a incidentes e testes contínuos para validar os processos de recuperação.
- Mas, as infraestruturas críticas corporativas para as quais o **CISO** deve inicialmente garantir a capacidade de recuperação são a **Active Directory (AD)**, a infraestrutura de **Backups** e as plataformas de distribuição e instalação de software!

- A capacidade de recuperação como última defesa garante que uma organização pode **restaurar as operações** após um incidente.

Elementos Mínimos:

- Garantir sistema de segurança e recuperação da **Active Directory (AD)**!
- Garantir sistemas de **BACKUP** confiáveis. Se possível sobre **secure Linux**!
- Manter cópias da informação mais crítica “offsite”! Incluindo versões dos sistemas operativos em uso (servidores e sistemas de rede).
- Testar periodicamente a recuperação dos **BACKUPS**!

Principais Desafios?

1. Garantir base mínima para enfrentar eventuais eventos “**Black Swan**”:

- a) Garantir a segurança e rápida recuperabilidade da **infraestrutura AD** (ou **Entra-ID**)!
- b) Garantir a segurança e rápida recuperabilidade da infraestrutura de **BACKUPS**!
- c) Garantir a segurança e rápida recuperabilidade da infraestrutura de **DISTRIBUIÇÃO de SOFTWARE e PATCHES de SEGURANÇA**!
- d) Redundância com isolamento de ativos chave.
- e) Outros ...

2. Aprender com falhas e melhorar → garantir **Antifragilidade**!

3. Garantir métricas que reflitam essa evolução, ou não!

**E para
concluir!**

A *Cibersegurança* não pode ser reativa. Tem de ser continuamente proativa! Especialmente no combate ao *Ransomware*!

E isso pode ser
conseguido através da
Doutrina Holística e
Proativa que propomos
e respetivos
mecanismos de
controlo e automação!





Cyber**security**.

Security is a Team effort, starting with You!
But always under Proactive Governance!

redshift



*Cyber***security.**

Security is a Team effort, starting with You!
But always under Proactive Governance!



Redshift Global . *Quem somos!*



Redshift
Cyber Summit

powered by *Redshift Strategic Partners*

Grupo de 3 Empresas

5 AREAS



Redshift Consulting

Cybersecurity Solutions
Cyber Managed Services
Security Operations
Consulting Services
Cybersecurity Training

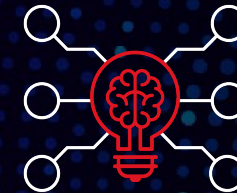
2 AREAS



Redshift Solutions

Information Management
Low Code

4 AREAS



Redshift Innovation

RED.Box
RED.Doc & RED.Scan
Red.Core
AI Integration, ML & Blockchain



redShift

Redshift Global . *Números*



Redshift
Cyber Summit

powered by *Redshift Strategic Partners*



Proveitos

13,8 M€

(2024)

+ 281%

(2021-2024)



Realizações

+200.000 Users servidos

+200 Clientes

+350 Projectos (todos os segmentos de mercado)



Human Firewall

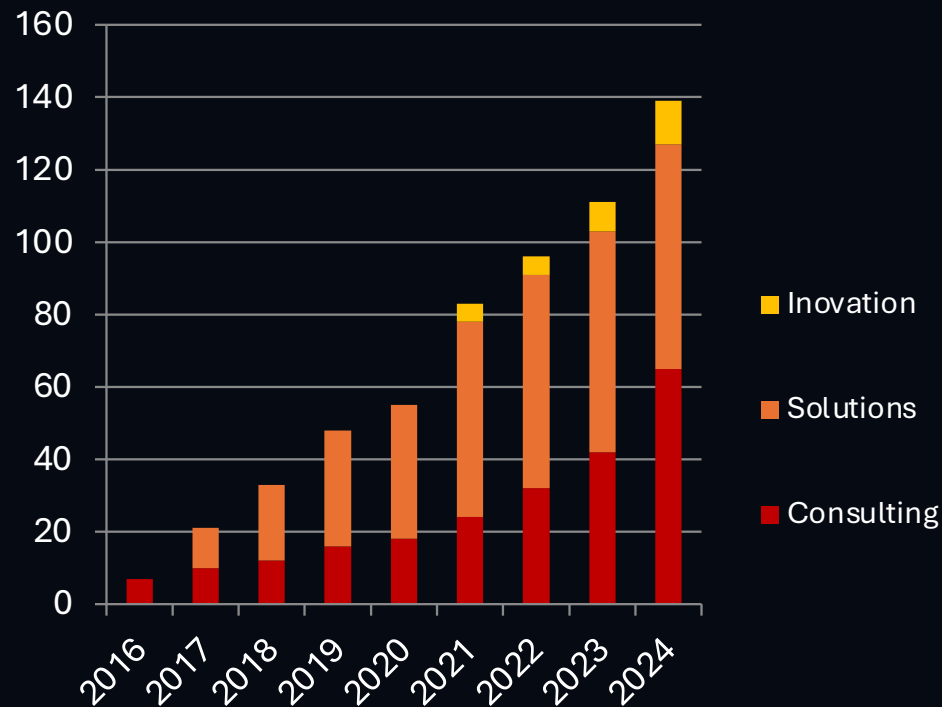
+140 Recursos Humanos

+130 Tecnicos/Engenheiros

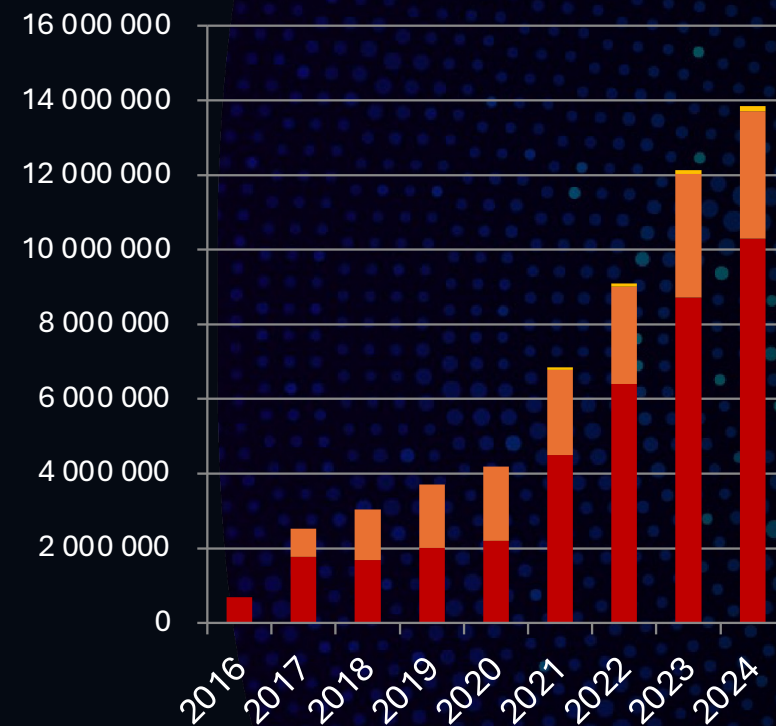




Pessoal (85% Technical)



Faturação Anual



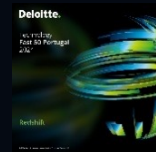
Redshift Global . Prémios & Reconhecimentos



**Partner of the
year HPE**



2020
2023
PME Líder



Melhores PME Portugal



**2024
Best Gold
Authorized
Partner**



2020
Financial Times
In the list of 1000 Europe's
fastest
growing companies
900th in Europe
13th in Portugal
7th in Cybersecurity in Europe
1st in Cybersecurity in Portugal



2022
2021
**Cybersecurity
Partner of the Year
IBM**



PME líder'23

2024
Deloitte Technology
Fast 50 Portugal

2023
2020
Deloitte
Technology Fast 500
EMEA Winners
451st in Europe
27th in Portugal
3rd in Cybersecurity in
Portugal



2024
2023
2022
**Innovative
COTEC**



2024
+ 250 Outsystems
Certifications

redShift

Redshift Global . *Certificações*

O nosso foco em *qualidade*

Nacional Secreto



NATO Secret



EU Secret



ISO 27001



ISO 9001



Incident Response



Redshift
Cyber Summit

powered by *Redshift Strategic Partners*



redShift

Obrigado!



José A. S. Alegria

Redshift Board Advisor

CIWA Strategic Advisor

Former CISO @ Altice

Former Worldwide CyberWatch Coordinator

@ Altice Group

Former EUROPOL Advisor